SEFU HMIS — Comprehensive Incident Response Plan (IRP)

Kenya Digital Health Agency (DHA) Certification Compliance Document

Category: Information Security Documentation — Section C: Incident Response

System Classification: Health Information System (HIS) & Electronic Medical Record (EMR)

Applicable Regulations: Kenya Data Protection Act 2019 (ODPC Section 43), Kenya Computer Misuse and Cybercrimes Act 2018, Kenya Digital Health Act 2023, ISO/IEC 27035 (Information Security Incident Management)

■ 1. Executive Summary & Governance

Attribute	Specification
Document Title	Cybersecurity & Healthcare Data Breach Incident Response Plan (IRP)
System Name	SEFU Hospital Management Information System (SEFU HMIS)
System Version	Release 5.0 (Build 2026-Kenya-DHA)
Document Version	1.0 (Production / Certification Ready)
Document Owner	Chief Information Security Officer (CISO) & Data Protection Officer (DPO)
Effective Date	November 2026
Review Frequency	Bi-annually or immediately following any confirmed security incident
Classification	Highly Confidential — Security Operations Documentation

---

■ 2. Purpose & Scope

2.1 Purpose

The purpose of this Incident Response Plan (IRP) is to establish a rigorous, disciplined framework for detecting, containing, investigating, and recovering from information security incidents and health data breaches affecting SEFU HMIS. It ensures rapid containment of cyber threats, minimizes operational impact, preserves forensic evidence, and guarantees strict compliance with statutory breach notification timelines stipulated by the **Office of the Data Protection Commissioner (ODPC) Kenya** and the **Digital Health Agency (DHA)**.

2.2 Scope

This plan covers:

- Physical server hardware, cloud hosting environments, virtual machines, and network switches.
- Database engines, stored patient health data, and backups.
- Web application code, REST APIs, and third-party integrations (e.g. SHA claims, lab analyzers).
- Clinical staff terminals, workstations, and administrative credentials.

■ 3. Incident Severity Levels & Triage Matrix

Security incidents are categorized into four severity tiers based on patient clinical safety impact, confidentiality breach scope, and operational disruption:

Severity Tier	Incident Definition & Example Scenarios	Target Initial Response	Escalation & Regulatory Reporting
Severity 1 (Critical / Data Breach)	Confirmed ransomware deployment; exfiltration or unauthorized exposure of patient medical records; total system compromise.	**< 15 Minutes**	**Full CSIRT Activation.** Immediate C-Suite convening. **Mandatory notification to ODPC Kenya within 72 hours (Section 43, DPA 2019)** and DHA.
Severity 2 (High)	Large-scale brute-force attack; compromised physician account; unauthorized alteration of financial/clinical records.	**< 30 Minutes**	CISO, Lead DBA, and DPO mobilized. Forensic audit of `logs` table initiated.
Severity 3 (Medium)	Isolated malware detection on a nurse terminal; suspicious failed login spikes; localized service denial.	**< 2 Hours**	Systems Engineer and Network Administrator contain node; patch deployed.
Severity 4 (Low / Info)	Minor port probe detected; spam email reported by clerk; benign software glitch.	**< 8 Hours**	Handled during standard administrative operations; logged in weekly audit report.

■ 4. The 6-Phase Incident Response Lifecycle

SEFU HMIS adheres to the internationally recognized **NIST SP 800-61 / ISO 27035** six-stage incident response methodology:

```
[Phase 1: Preparation] ■■■ [Phase 2: Detection & Analysis] ■■■ [Phase 3: Containment]
■
[Phase 6: Lessons Learned] ■■■ [Phase 5: Recovery] ■■■ [Phase 4: Eradication]
```

Phase 1: Preparation

- Continuous audit logging of all Insert, Update, and Delete actions in the `logs` table.
- Login tracking in `userlog` table with IP, timestamp, user agent, and role.
- Regular staff cybersecurity awareness training against phishing and credential theft.
- Implementation of Multi-Factor Authentication (MFA via Email OTP) and strict password complexity.

Phase 2: Detection & Analysis

- **Monitoring Channels:** Automated error logs (`application/logs/`), database audit trails (`admin/audit`), web server access/error logs, and staff incident reports.
- **Triage Checklist:**

1. Determine the attack vector (Phishing, web vulnerability, brute force, insider misuse).
2. Identify affected systems and user accounts.
3. Assess whether Personal Health Information (PHI) or financial data was accessed or exfiltrated.
4. Assign initial Severity Rating (1 to 4).

Phase 3: Containment

- **Short-Term Tactical Containment:**
- Sever network connection of affected hosts (disconnect LAN cables, disable virtual NIC).
- Terminate compromised user sessions and invalidate active cookies.
- Temporarily restrict external IP access via firewall rules (`iptables` / Windows Defender Firewall).
- **Long-Term Containment:**
- Isolate clean backup media to prevent cross-contamination.

- Apply emergency firewall blocks on malicious origin IP addresses and domains.

Phase 4: Eradication

- Locate and neutralize root cause (e.g., remove web shell, terminate malicious process, clean infected workstation).
- Identify and patch underlying vulnerabilities (update CodeIgniter libraries, sanitize inputs, enforce stricter RBAC rules).
- Revoke and regenerate all system passwords, database connection strings, and API secret keys.

Phase 5: Recovery & Verification

- Restore affected databases and application files strictly from verified, uncorrupted backup snapshots.
- Execute cryptographic checksum validation (SHA-256) on restored datasets.
- Re-enable services under heightened monitoring and verify all clinical modules (OPD, IPD, Pharmacy, Lab).
- Conduct functional and security sanity testing before releasing system to hospital staff.

Phase 6: Post-Incident Review & Lessons Learned

- Convene a formal **Post-Incident Review Meeting** within 5 business days.
- Produce a comprehensive **Root Cause Analysis (RCA)** report detailing:
- Timeline of the incident from initial intrusion to full resolution.
- Vulnerabilities exploited and corrective engineering measures taken.
- Preventive safeguards added to avoid recurrence.
- Archival of all forensic evidence for legal compliance.

■■ 5. Statutory Regulatory Breach Notification Protocol (ODPC & DHA Kenya)

In the event of a **Severity 1** security incident involving unauthorized access, exposure, alteration, or exfiltration of sensitive patient personal health records:

5.1 The 72-Hour ODPC Notification Rule (Section 43, Kenya Data Protection Act 2019)

The Data Protection Officer (DPO) must submit formal notification to the **Office of the Data Protection Commissioner (ODPC) Kenya** within **72 hours** of becoming aware of the breach:

Mandatory Contents of ODPC Notification:

1. Nature of the personal data breach, including categories and approximate number of data subjects (patients/staff) affected.
2. Likely consequences of the personal data breach on patient privacy and safety.
3. Technical and organizational measures taken or proposed to mitigate possible adverse effects.
4. Name and contact details of the hospital's registered Data Protection Officer.

5.2 Patient / Data Subject Notification

If the breach is likely to result in high risk to patient rights, dignity, or privacy:

- The hospital must directly communicate the breach to affected patients in clear and plain language via SMS, email, or written letter without undue delay.

5.3 Kenya Digital Health Agency (DHA) & NC4 Notification

- Immediate technical advisory dispatched to the **Kenya Digital Health Agency (DHA)** incident desk.
- Coordination with the **National Computer and Cybercrimes Coordination Committee (NC4)** for law enforcement investigation.

■ 6. Incident Response Team (CSIRT) Roster & Roles

Role	Designee	Incident Responsibilities
Incident Commander	Chief Technology Officer (CTO)	Leads overall response strategy, authorizes emergency shutdowns, directs technical leads.
Lead Security Investigator	Lead Information Security Engineer	Conducts log analysis, analyzes malware, isolates compromised assets.
Database Administrator (DBA)	Lead Database Architect	Assesses database integrity, coordinates clean restoration from backup, audits query logs.
Data Protection Officer (DPO)	Legal & Compliance Lead	Assesses legal exposure, drafts ODPC breach notifications, handles patient data rights.
Hospital PR & Communications	Communications Director	Manages staff announcements and public communications (no unauthorized public disclosures).

■ 7. Emergency Contact & Notification Directory

- **ODPC Kenya Breach Notification Portal:** `https://www.odpc.go.ke` | `complaints@odpc.go.ke`
- **Kenya Digital Health Agency (DHA) Helpdesk:** `dha.go.ke`
- **National Cyber Security Centre (NC4):** `incident@nc4.go.ke`
- **Hospital Emergency CSIRT Hotline:** `+254 700 000 000` (24/7/365 Monitored)

Approved by:

Chief Information Security Officer & Data Protection Officer

SEFU Health Systems — Kenya Digital Health Agency (DHA) Compliance